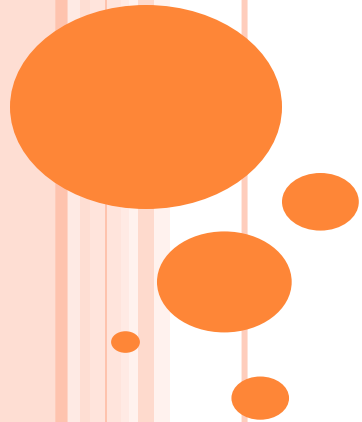


TOKEN JWT



Token vs autenticación básica

➤ Un token es una cadena de caracteres codificada que incluye el identificador de usuario, rol y otros datos adicionales:

38dfa4a229e002efd11.\$2ee44opgm

➤ Mientras que con la autenticación básica se deben enviar siempre las credenciales para autenticar y autorizar al usuario, utilizando tokens la autenticación se realiza una sola vez para generar el token, el resto de peticiones envían el token generado en el que se incluye toda la información del cliente

➤ El token es más seguro, dado que no incluye contraseña.



¿Qué es un token JWT?

- Mecanismo para comunicar de forma segura un microservicio con una aplicación cliente y proceder a su identificación.
- Se basa en el uso de una cadena JSON codificada y firmada, que incluye los datos del cliente (usuario, roles,...).
- El cliente envía el token JWT al microservicio en la cabecera de las peticiones, éste la decodifica y verifica que no ha sido alterada en tránsito, extrayendo a continuación la información del cliente para proceder a su autorización.

petición
HTTP

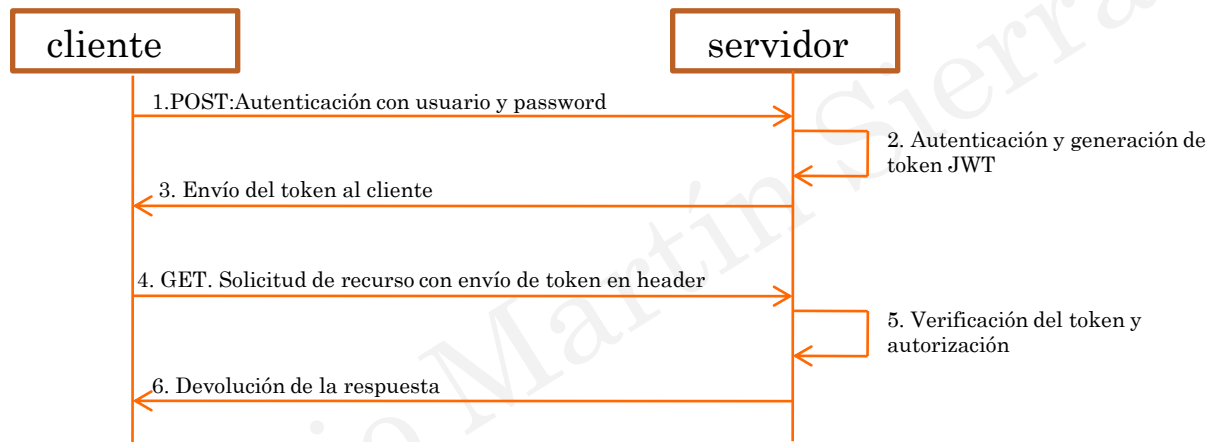
cabecera

authorization=token_jwt

cuerpo



Funcionamiento



Estructura de un token JWT

➤ Un token JWT es una cadena codificada que consta de tres partes separadas por un ".":

header . payload . signature

```
header {
  {
    "alg": "HS256",
    "typ": "JWT"
  }
}

payload {
  {
    "iat": 1632173019,
    "sub": "admin",
    "authorities": [
      "ROLE_ADMIN",
      "ROLE_USER"
    ],
    "exp": 1632259419
  }
}

signature {
  HMACSHA256(
    base64UrlEncode(header) + "." +
    base64UrlEncode(payload),
    secret_key
  )
}
```

header: Incluye dos campos, el tipo de token (siempre JWT) y el mecanismo de firma

payload: Contiene la información del cliente, como el nombre, roles, etc. También el tiempo de vida del token

signature. Se construye utilizando la función especificada en la cabecera y que recibe como parámetro la cabecera más el payload codificado, además de la clave secreta preestablecida. Esto permite verificar la integridad del mensaje

eyJhbGciOiJIUzUxMiJ9
.eyJpYXQiOiE2MzQxNDI0ODgsInN1YiI6ImFkbWluIiwiaXV0aG9yaXRpZXMiOiUk9MRV9BRE1JTilIsIlJPTeVfVVNFUiJdLCJleHAiOiE2MzQyMjg4ODh9
.JsiPFdtOjkCW5AwwmloE3cz_WTl3ZM9CC4_ZKw7XbBH-zEedc0-geuYEc3BIWM3Yf7dtZQA3c5mmToRizIjk6g